

INITIAL HIPAA ASSESSMENT

This high-level, billing agency-wide analysis will help you assess your current compliance with HIPAA standards, identify enablers and develop action plans to achieve compliance. Before diving into the in-depth Privacy and Security assessments perform this Initial Assessment to identify HIPAA compliant business practices that are currently in place.

ACTIVITY	Completed	In Process	Not Started	Not Applicable	Don't Know
General & Billing Agency Management					
Have you obtained, and do you thoroughly understand, the proposed HIPAA rules? Have you signed up for e-mail updates to these documents?					
Has your billing agency added HIPAA compliance to your strategic plans?					
Has your billing agency conducted an inventory of your assets for HIPAA compliance?					
Have objectives for the HIPAA Compliance Plan been established?					
Has your billing agency appointed an individual or group responsible for HIPAA information and compliance planning?					
Has the billing agency conducted an billing agency-wide assessment and gap analysis with respect to HIPAA compliance?					
Has the billing agency conducted a comprehensive, billing agency-wide inventory of its information systems?					
Has the HIPAA compliance need for each information system been determined?					
Is your comprehensive two-year HIPAA Compliance Plan consistent with IS and corporate strategic plans?					
Have project plans been created for each HIPAA related project?					
Have you created a step-by-step implementation work plan?					
Have contingency plans been developed, reviewed, tested, approved and put in place?					
Has your billing agency reviewed or analyzed previously undertaken Y2K activities in the last 12 months to create or change data security and privacy practices?					
Has the billing agency developed resources (publications, seminars, websites, professional networking, etc.) to facilitate the billing agency's approach to HIPAA compliance?					

ACTIVITY	Completed	In Process	Not Started	Not Applicable	Don't Know
Have employees, students or volunteers received specific training on the confidentiality of health information and their responsibilities?					
Standardization of Electronically Transmitted Data					
Does your billing agency currently send or receive health claims electronically?					
Does your billing agency currently send or receive payment or remittance advice electronically?					
Does your billing agency currently send or receive premium payments or capitation electronically?					
Does your billing agency currently send or receive prior authorizations or referrals electronically?					
Does your billing agency currently send or receive notification of health claim status electronically?					
Does your billing agency currently send or receive enrollment and disenrollment electronically?					
Does your billing agency currently send or receive eligibility electronically?					
Does your billing agency currently perform COB electronically?					
Does your billing agency currently use the ANS ASC X12N Version 4010 standards named in the HIPAA final regulations for these electronic transactions?					
Does your billing agency bill or process outpatient online or batch prescription drug claims using the NCPDP Version 5.1 and Version 1.1 standards respectively?					
Does your billing agency currently send or receive data in HL7 format?					
Does your billing agency receive individually identifiable patient information from a health plan, healthcare clearinghouse or healthcare provider or from a business partner of one of these entities?					
Does your billing agency use these standards when sending the above transactions inside corporate boundaries?					
Does your billing agency have a migration plan for EDI solutions?					
Do you currently have a translator on site?					
Do you currently use a switch/clearinghouse for translator/routing services?					

ACTIVITY	Completed	In Process	Not Started	Not Applicable	Don't Know
Standardization of Code Sets					
Does your billing agency currently use HCPCS Level 3 or local codes for billing or payment?					
Does your billing agency use ICD9 Volume 3 Procedures for billing or paying hospital inpatient procedures?					
Does your billing agency use J codes and X, Y, Z codes for billing or payment?					
Does your billing agency rely on "local" coding schemes to conduct business?					
Is payer and provider compliance with official coding guidelines being monitored?					
Does the staff receive routine training on current coding practices?					
Information Security					
Does your billing agency have formal, written security policies?					
Are security policies and procedures strictly enforced?					
Has your billing agency reviewed its security policies and procedures in the last six months?					
Has your billing agency identified your risks and areas of exposure?					
Are procedures in place to monitor for fraudulent behavior? If so, are they enforced with employee disciplinary action?					
Do you have a procedure for handling natural and man-made disasters?					
Is there a disaster recovery and business continuity policy in effect?					
Has your billing agency analyzed the business to determine the key requirements of a successful recovery?					
Does your billing agency's security for each information system individually identify and authenticate each system user?					
Is there an automatic logoff after a specified time?					
Does your billing agency have and follow policies and procedures in the event of termination of an employee with access to identifiable health information?					
Are passwords canceled when employees leave?					
Are audit trails and management reports available to monitor access?					
Is the computer room secure?					
Is a secure environment provided for all equipment at all times?					

ACTIVITY	Completed	In Process	Not Started	Not Applicable	Don't Know
Does your billing agency have written policies governing the receipt and removal of hardware/software into and out of a facility?					
Are the billing agency's information systems periodically backed up with the back-up data maintained off-site in a secure location?					
Does your billing agency use or plan to use digital signatures within the next 12 months?					
Has your billing agency ever used network assessment software for vulnerabilities?					
Does your billing agency have written procedures for reporting and responding to computer security breaches?					
If your billing agency uses computer networks or the Internet to transact business, does it have documented procedures, software and hardware that assure the integrity of data, authenticate the message and verify the identity of the sender and recipient?					
Has the billing agency designated an information security officer?					
Does your billing agency have policies covering the control of access to patient-identifiable health information?					
Does your billing agency monitor access to patient information?					
Privacy					
Does your billing agency have a person specifically identified to be in charge of health data privacy?					
Does your billing agency use or disclose individually identifiable health information for reasons other than treatment, payment or healthcare operations?					
Has your billing agency researched your State law and determined in what areas State law will pre-empt HIPAA privacy regulations?					
Has your billing agency drafted a Notice of Privacy Practices that states the uses and disclosures your billing agency intends to make with protected health information as required by HIPAA?					
Does your billing agency have written policies that identify and confirm the identity of a user when he or she tries to access health data?					
If your billing agency's personnel have access to patient records or copies of them, are procedures in place to protect the confidentiality of these records?					

ACTIVITY	Completed	In Process	Not Started	Not Applicable	Don't Know
Has your billing agency reviewed existing vendor contracts to ensure that they comply with the proposed HIPAA requirements?					
If your billing agency uses contractors and/or vendors to provide services that involve health information (such as statistical processing, photocopying, transcription, storage/retrieval, microfilming, scanning, destruction of information or information systems support), have the contractors and/or vendors signed contracts restricting their use and disclosure of protected health information?					
Are there adequate procedures to protect patient-related financial data that contain diagnostic or procedural codes that may reveal the reason for a patient's treatment?					
Has your billing agency developed a mechanism for accounting for all disclosures of protected health information for purposes other than treatment, payment or healthcare operations?					
Has your billing agency developed a privacy training program for employees and a system of sanctions ranging from retraining to termination for employees who are in violation of privacy policies?					